

3

Critique

1

Majeur

4

Total findings

Conformité OWASP MASVS

MASVS-CRYPTO-1

L'app n'utilise pas de primitives cryptographiques faibles ou dépréciées.

[→ Voir contrôle OWASP officiel](#)

ÉCHOUÉ — 3 violation(s)

MASVS-CRYPTO-2

L'app utilise des implémentations éprouvées de primitives cryptographiques.

[→ Voir contrôle OWASP officiel](#)

ÉCHOUÉ — 1 violation(s)

Référentiel OWASP utilisé

Les vulnérabilités sont mappées selon [MASVS-CRYPTO-1](#) et [MASVS-CRYPTO-2](#) du standard OWASP MASVS. Les corrections sont générées par IA (LLaMA 3.3 70B) basées sur les recommandations MASTG officielles.

Findings détectés

Sévérité	Contrôle OWASP	Vulnérabilité	Fichier	Ligne	Code vulnérable	Explication IA
CRITIQUE	MASVS-CRYPTO-1	AES/ECB — Mode non sécurisé "L'app n'utilise pas de primitives cryptographiques faibles ou dépréciées."	C0000a.java	14	SecretKeySpec secretKeySpec = new SecretKeySpec(bArr, "AES/ECB/PKCS7Padding");	L'utilisation de 'AES/ECB/PKCS7' considérée comme un mode de chiffrement non sécurisé. Le mode ECB (Electronic Code Book) est vulnérable à l'analyse de fréquences. De plus,

peut être vulnérable aux attaques de padding. L'utilisation de 'AES/GCM/NoPadding' (Initialisation Vector) est recommandée (Galois/Counter mode de chiffrement sécurisé qui fournit confidentialité et authenticité).

CRITIQUE

MASVS-CRYPTO-1

Clé cryptographique hardcodée

"L'app n'utilise pas de primitives cryptographiques faibles ou dépréciées."

C0000a.java

7

```
import javax.crypto.spec.SecretKeySpec;
```

La vulnérabilité MASVS-CRYPTO-1 concerne l'utilisation de primitives cryptographiques faibles ou dépréciées dans le code vulnérable. Le code 'javax.crypto.spec.SecretKeySpec' peut indiquer l'utilisation d'une clé secrète statique pour le chiffrement, ce qui est considéré comme une pratique non sécurisée. L'utilisation d'une clé statique peut être détectée si l'application est analysée et la clé est exposée.

CRITIQUE

MASVS-CRYPTO-1

Clé cryptographique hardcodée

"L'app n'utilise pas de primitives cryptographiques faibles ou dépréciées."

C0000a.java

14

```
SecretKeySpec secretKeySpec = new SecretKeySpec(bArr, "AES/ECB/PKCS7Padding");
```

L'utilisation de primitives cryptographiques dépréciées, telles que 'AES/ECB/PKCS7Padding', peut compromettre la sécurité de l'application. Le mode ECB (Electronic Code Book) est considéré comme non sécurisé car il ne fournit pas de confidentialité et peut être vulnérable à l'analyse de fréquence. De plus, PKCS7Padding n'est pas recommandé pour les applications. L'utilisation d'un système de clés sécurisé est recommandée pour gérer les clés de manière sécurisée.

MAJEUR

MASVS-CRYPTO-2

Cipher sans mode spécifié

"L'app utilise des implémentations éprouvées de primitives cryptographiques."

C0000a.java

15

```
Cipher cipher = Cipher.getInstance("AES");
```

La vulnérabilité MASVS-CRYPTO-2 concerne l'utilisation de l'implémentation par défaut de chiffrement AES sans spécifier de mode de chiffrement ou de padding. L'utilisation de 'Cipher.getInstance("AES")' conduit à l'utilisation du mode de chiffrement par défaut, qui est considéré comme non sécurisé. De plus, le padding n'est pas spécifié, ce qui peut entraîner des problèmes de sécurité tels que des attaques de padding.

secrète tels que
padding oracle.

